

**** LAB ** Enumerazione [25 febbraio]**

Sito: [Virtuale](#)
Corso: Laboratorio di Sicurezza Informatica T
Libro: ** LAB ** Enumerazione [25 febbraio]

Stampato da: Lorenzo Bernardini
Data: lunedì, 4 maggio 2026, 14:29

Descrizione

SLIDE: [Strumenti e metodi per l'enumerazione di host, servizi, e utenti](#)

All'interno del book: esercitazione di enumerazione su "Tre target combinati" reperibili nella sezione [Immagini di VM utilizzabili sul proprio PC](#)

Sommario

1. Predisporre i target
2. Enumerazione degli host e dei servizi
3. Risultato atteso enumerazione host e servizi
4. Misconfiguration servizi
5. Accesso con credenziali ed esplorazione dall'interno
6. Hash cracking con wordlist custom

1. Predisporre i target

Con lo stesso metodo usato per Parrot, create tre macchine virtuali a partire dai dischi `Appliance-disk001.vdi` / `Appliance-disk002.vdi` / `Appliance-disk003.vdi` che trovate in `/opt/owa`.

Breve recap (da ripetere per i tre dischi):

- create una VM da VirtualBox
 - Tipo Linux - debian 64 bit
 - 1 core
 - 1024 MB RAM
 - scegliete il file vdi come disco esistente
- **impostate la scheda di rete su "Host-only (vboxnet0)"**
 - *se le macchine non acquisiscono un indirizzo IP, controllate dal Network Manager di Virtualbox (si apre con Ctrl+H) che la rete host only abbia il server DHCP abilitato*
- **prima di avviare la macchina scattate uno snapshot**
- avviate
 - il terminale non vi serve - se non per osservare che il boot proceda correttamente e per prendere nota del nome della VM

2. Enumerazione degli host e dei servizi

Per verificare quali host di una rete rispondono al ping:

```
nmap -sn 192.168.56.0/24
```

(rete tipica della Host-only network di Virtualbox, aggiustate se necessario)

Supponiamo di aver individuato

- 192.168.56.32
- 192.168.56.33
- 192.168.56.34

Ora per individuare le porte aperte usiamo

```
nmap -sT 192.168.56.32-34
```

Limiti:

- non esplora tutte le porte!
 - guardate la man page e usate il parametro `-p`
- non verifica che il servizio sia veramente quello standart per la porta
 - usate `-sV` al posto di `-sT`. in combinazione con `-p` per interrogare solo le porte aperte
- specifico per TCP
 - guardate sulla man page altri tipi di scansione

DA FARE:

- Esplorate le modalità alternative di scansione di nmap, incluse quelle che consentono di integrare moduli che lo trasformano in un vero e proprio tool di Vulnerability Assessment
- Utilizzate Greenbone, esplorate le funzionalità, definite un task per effettuare un VA sulle tre macchine e leggete il report

3. Risultato atteso enumerazione host e servizi

```
nmap -sT 192.168.56.32-34 -p-
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-25 17:43 CET
Nmap scan report for 192.168.56.32
Host is up (0.0073s latency).
Not shown: 65531 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
3306/tcp  open  mysql
5432/tcp  open  postgresql
```

```
Nmap scan report for 192.168.56.33
Host is up (0.00082s latency).
Not shown: 65528 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
110/tcp   open  pop3
143/tcp   open  imap
993/tcp   open  imaps
995/tcp   open  pop3s
1337/tcp  open  waste
```

```
Nmap scan report for 192.168.56.34
Host is up (0.00089s latency).
Not shown: 65528 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
8000/tcp  open  http-alt
8001/tcp  open  vcom-tunnel
```

Scansione approfondita:

```
nmap -sV 192.168.56.32 -p 22,80,3306,5432
```

(nessuna sorpresa)

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-25 17:47 CET
Nmap scan report for 192.168.56.32
Host is up (0.00050s latency).

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 9.2p1 Debian 2+deb12u4 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.65 ((Debian))
3306/tcp  open  mysql        MariaDB 10.3.23 or earlier (unauthorized)
5432/tcp  open  postgresql   PostgreSQL DB 9.6.0 or later
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
nmap -sV 192.168.56.33 -p 22,25,110,143,993,995,1337
```

(notate che il servizio originariamente classificato "waste" è in realtà ssh!)

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-25 17:47 CET
Nmap scan report for 192.168.56.33
Host is up (0.00043s latency).
```

```
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 9.2p1 Debian 2+deb12u4 (protocol 2.0)
25/tcp    open  smtp         Postfix smtpd
110/tcp   open  pop3         Dovecot pop3d
```

```
143/tcp open  imap      Dovecot imapd
993/tcp open  ssl/imap  Dovecot imapd
995/tcp open  ssl/pop3  Dovecot pop3d
1337/tcp open  ssh       OpenSSH 9.2p1 Debian 2+deb12u4 (protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
nmap -sV 192.168.56.34 -p 22,53,80,139,445,8000,8001
```

(notate il servizio sulla porta 8000 non riconoscibile, ma che produce prompt di richiesta username e password, e il servizio sulla porta 8001 che è un server web)

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-25 17:49 CET
```

```
Nmap scan report for 192.168.56.34
```

```
Host is up (0.00040s latency).
```

```
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 9.2p1 Debian 2+deb12u4 (protocol 2.0)
53/tcp    open  domain       ISC BIND 9.18.41-1~deb12u1 (Debian Linux)
80/tcp    open  http         Apache httpd 2.4.65 ((Debian))
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
8000/tcp  open  http-alt?
8001/tcp  open  http         Werkzeug httpd 3.1.3 (Python 3.11.2)
```

```
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
```

```
SF-Port8000-TCP:V=7.95%I=7%D=2/25%Time=699F2820%P=x86_64-pc-linux-gnu%(NU
SF:LL,A,"Username:\n")%r(GenericLines,3C,"Username:\n\x20Password\x20\
SF:rter\x20than\x2025\x20chars\):\nWrong\x20username\n")%r(GetRequest,3C,"
SF:Username:\n\x20Password\x20\
SF:20username\n")%r(X11Probe,A,"Username:\n");
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

4. Misconfiguration servizi

Un errore di configurazione può svelare dettagli del sistema attraverso servizi pubblici, o persino esfiltrare dati sensibili

Es. un server SMTP consente VRFY per testare la validità di username, un "banner" rivela l'architettura precisa dell'host.

In questo caso abbiamo diversi servizi "problematici"

- SMTP, POP, IMAP
 - posta elettronica = accettano necessariamente connessioni dall'esterno; cosa posso scoprire?
 - partiamo dalla connessione più semplice possibile con *netcat*:

```
nc 192.168.56.133 25
```

```
220 Talk to Postgres admin to get more info
```

...interessante indizio
- MARIADB, POSTGRES
 - interrogazione database: non ha normalmente senso che siano accessibili fuori dalla rete locale.
 - Usate i client nativi per connettervi e scoprire cosa è visibile:

```
psql -U admin -h 192.168.56.104 -W -l
```
 - tiro a indovinare la password: admin
 - scoperto il nome del db, mi connetto,

```
psql -U admin -h 192.168.56.104 -W accounts_db
```
 - elenco le tabelle

```
\dt
```
 - le esploro

```
SELECT * FROM accounts;
```
 - [una guida più ampia](#)

DA FARE:

- ci sono strumenti su Parrot per interrogare automaticamente il server SMTP?
- si può scoprire qualcosa tramite gli altri servizi?
 - http (su porte standard e non)
 - mysql
 - pop/imap
 - netbios/microsoft

5. Accesso con credenziali ed esplorazione dall'interno

Avendo scoperto credenziali, il percorso di accesso più ovvio è via SSH

Abbiamo a disposizione 4 servizi ssh

- 192.168.56.32 porta 22
- 192.168.56.33 porta 22
- 192.168.56.33 porta 1337
- 192.168.56.34 porta 22

Provate le credenziali utente su tutti: noterete che alcuni servizi non accettano l'uso di password.

Dove si riesce a entrare come i tre utenti scoperti nel database?

Una volta loggati, si potrebbero cercare innumerevoli informazioni, limitiamoci a un suggerimento trovato in /home/turing/note.txt

Reminder: to get full control of t-2, use your 4-digit pin

Usando il suggerimento, tentiamo un accesso a forza bruta come root su t-2 (in questo esempio, 192.168.56.33), ricordando tutti i canali disponibili!

Hydra consente di effettuare tentativi di login su molteplici tipi di servizio, specificando nome utente e password, o file che contengono molteplici nomi utente e molteplici password, o anche generando password come semplici combinazioni di insiemi di caratteri.

Lanciate **hydra -h** e **hydra -x -h** per esplorare la sintassi e avere esempi di come generare 4-digit pin; il comando che useremo sarà infine:

```
hydra -l root -x 4:4:1 ssh://192.168.56.33:1337
```

6. Hash cracking con wordlist custom

Nella home di root, troviamo due file molto interessanti: copie di backup di file di credenziali

`passwd.bak`

`shadow.bak`

DA FARE:

- `passwd` ci guida verso la composizione di una wordlist custom con CUPP
- avendo gli hash di `shadow` possiamo svelare la password cercandola con JOHN